

Sécurité, coûts et appropriation

Comment la plateforme FASTR protège les données d'un pays — et ce qu'il faut pour la faire tourner

»» FASTR Useful Data

Sécurité des données

The background is a solid teal color. On the right side, there are several overlapping geometric shapes: a large dark teal quarter-circle in the top right, a smaller dark teal quarter-circle in the bottom right, and a series of concentric circles in a lighter teal shade that overlap with the other shapes.

Ce que contient la plateforme

- Des **totaux mensuels de services par établissement** — par exemple, 45 premières consultations prénatales dans une clinique en mars
- Les **mêmes chiffres que les rapports DHIS2** que le ministère produit déjà
- **Aucun dossier patient** — pas de noms, pas d'adresses, rien d'individuel

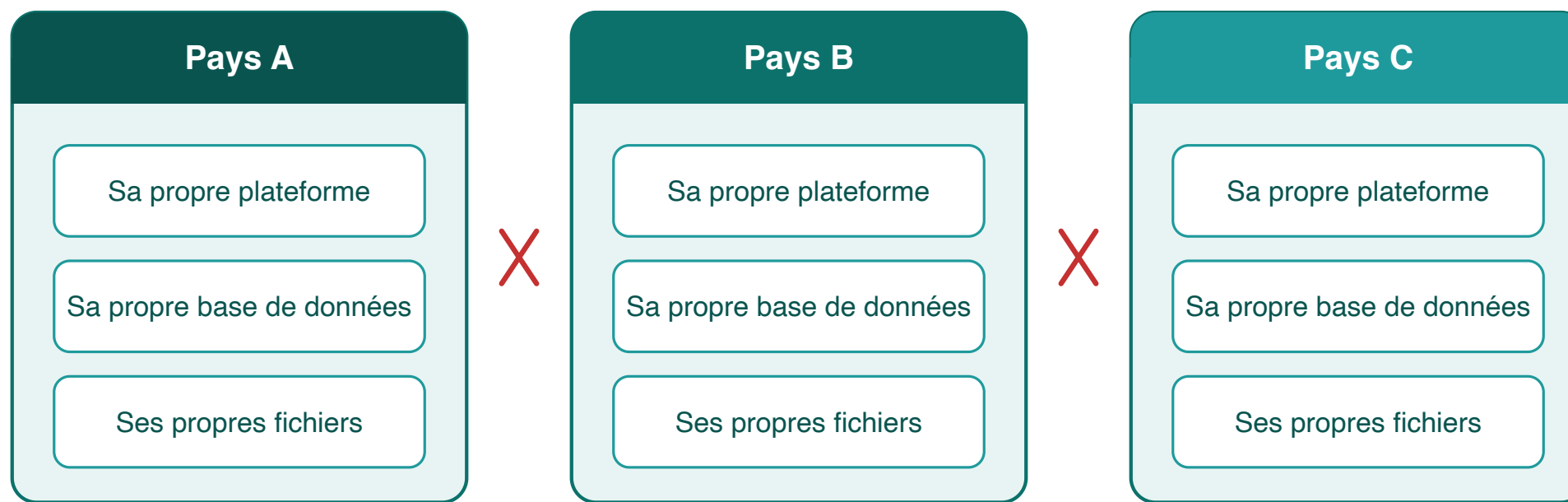
Quatre questions que tout gouvernement devrait poser

- Nos données peuvent-elles échapper au contrôle du pays ?
- La mauvaise personne peut-elle entrer ?
- Les données peuvent-elles être interceptées en chemin — ou perdues ?
- L'IA peut-elle exposer ce qu'elle voit ?

Les quatre diapositives suivantes les prennent une à une : le risque, puis ce qui y répond.

Nos données peuvent-elles échapper au contrôle du pays ?

Le risque : des données versées dans un pot commun, ou visibles d'un autre pays. **La réponse :** il n'y a pas de pot commun — chaque pays fonctionne sur sa propre installation, et le partage est techniquement impossible.



Aucune connexion entre les pays — par conception

La mauvaise personne peut-elle entrer ?

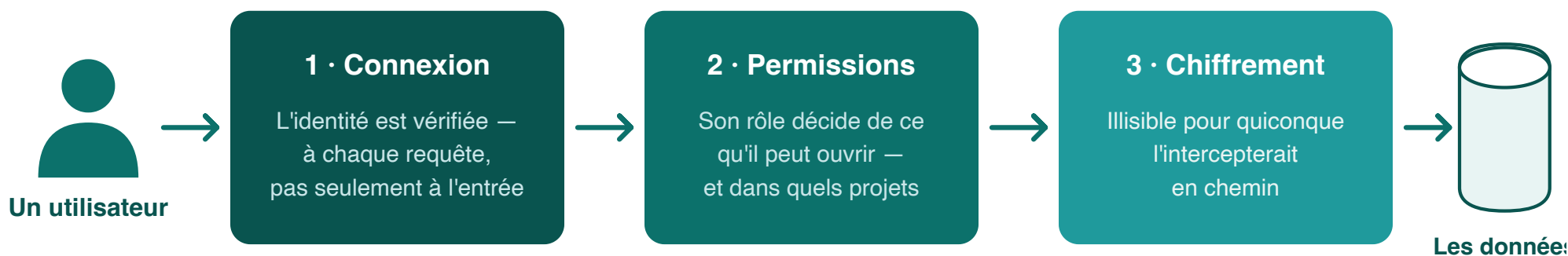
Le risque : un mot de passe qui fuite, ou un initié qui dépasse son rôle. **La réponse :** des comptes, des rôles, et une identité revérifiée à chaque requête.

- Le ministère décide **qui reçoit un compte**, et le rôle de chaque personne
- Le rôle fixe ce qu'une personne peut faire — **consulter, éditer ou administrer** — et dans quels projets
- L'identité est **revérifiée à chaque requête**, pas seulement à la connexion
- Seul un **petit groupe d'administrateurs identifiés** peut modifier la configuration

Les données peuvent-elles être interceptées — ou perdues ?

Le risque : une interception sur le réseau, ou une panne de serveur qui emporte les données. **La réponse :** rien de lisible ne quitte la plateforme, et des copies automatiques permettent de tout reconstruire.

Trois contrôles séparent un utilisateur des données

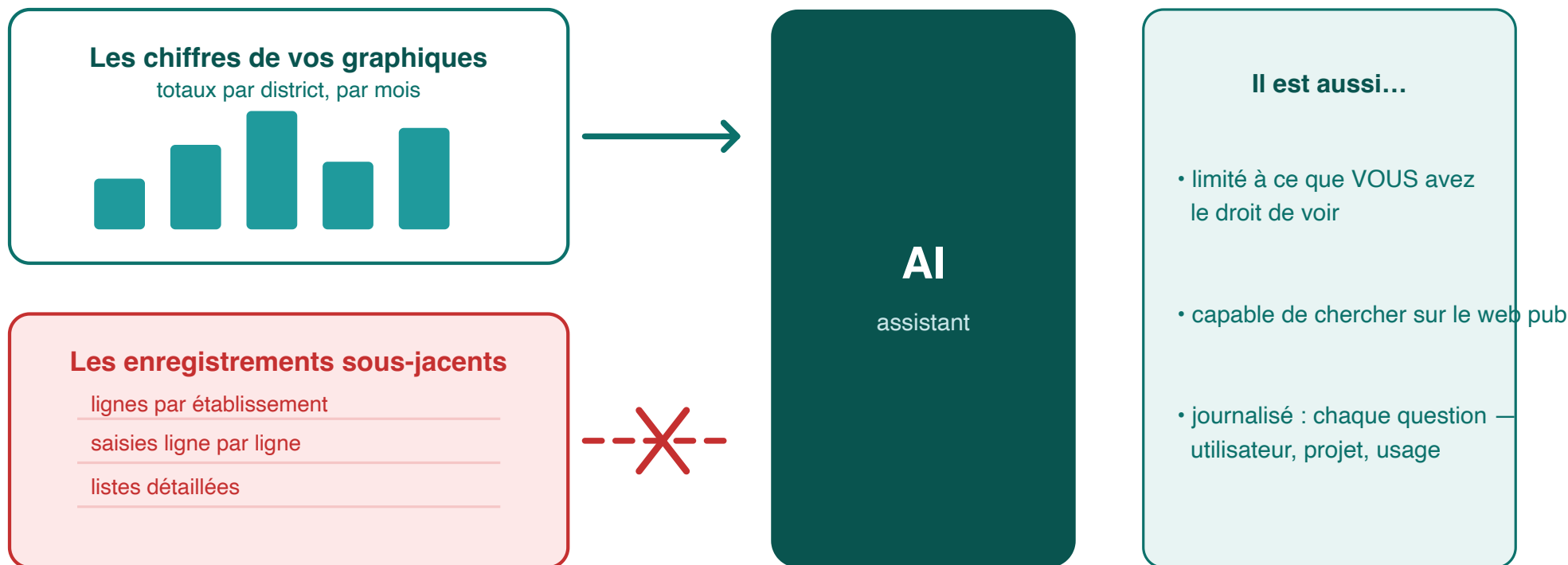


À part : la protection contre la perte

La base est sauvegardée toutes les 30 minutes, l'installation complète chaque jour — si un serveur tombe, tout peut être reconstruit

L'IA peut-elle exposer ce qu'elle voit ?

Le risque : un assistant qui en voit trop. **La réponse :** il ne reçoit que des totaux agrégés — les chiffres qu'un utilisateur verrait déjà, dans la limite de ses propres permissions. **Jamais les lignes en dessous.**



Coûts et appropriation

The background of the slide is a solid teal color. On the right side, there are abstract geometric elements: a large dark teal quarter-circle in the top right, a smaller dark teal quarter-circle in the bottom left, and two sets of concentric circles. One set of circles is centered near the bottom left, and the other is centered near the bottom right. The circles are a lighter shade of teal and overlap with the other shapes.

Coûts de fonctionnement

Trois lignes : **hébergement du serveur** (fixe), **usage de l'IA** (au compteur), **maintenance** (équipe partagée).
Pas de licence, pas de frais par utilisateur — le logiciel est open source.

Hébergement	Assistant IA	Personnes
Comme un loyer Un montant mensuel fixe pour le serveur du pays ≈ 500–800 USD / an	Comme l'électricité Au compteur — vous ne payez que ce qui est utilisé ≈ 350 USD / mois	Comme l'entretien Mises à jour, supervision, sauvegardes, appui aux utilisateurs ≈ 7–10 k USD / an, partagé

Estimations de planification, prix 2026 — ni licences ni frais par utilisateur

Les chiffres — estimations de planification

Estimations aux prix 2026 et à l'usage actuel. **Ce n'est pas un devis.**

- **Hébergement** de l'instance d'un pays : environ **500 à 800 USD par an** — les grands pays vers le haut de la fourchette
- **Usage de l'IA** : environ **350 USD par mois** (~4 000 USD par an) pour un pays typique ; plusieurs fois plus pour les plus grands pays, et cela croît avec l'usage
- **Maintenance partagée de la plateforme** (ingénierie, supervision, sauvegardes) : environ **7 000 à 10 000 USD par pays et par an** aujourd'hui — cela baisse à mesure que des pays rejoignent
- **Appui optionnel** (actualisation des données, contrôles qualité, analyses) : environ **5 000 à 15 000 USD par an** selon le niveau
- **Total : environ 12 000 USD par an** — jusqu'à 20 000–30 000 USD avec l'appui
- Les lignes incluent les services externes : le **service de connexion (Clerk)** et l'**API d'IA (Anthropic)** — aucun abonnement caché

- **Les économies d'échelle jouent déjà** : une seule équipe et un seul code servent tous les pays, la part de maintenance par pays baisse à mesure que des pays rejoignent — des économies qu'un

Hébergement — et ce que migrer demande vraiment

- Hébergée **de façon centralisée aujourd'hui**, pendant le développement actif — chaque pays reçoit correctifs et nouveautés le jour même
- Construite **portable** : le même logiciel tourne tel quel sur les serveurs d'un ministère — aucune reconstruction
- **Mais migrer est un projet, pas un interrupteur** : évaluation de préparation, achat des serveurs, formation de l'équipe, période de fonctionnement en parallèle, puis bascule — cela se compte en **mois, planifiés ensemble**
- **Et s'héberger seul, c'est porter seul** ce qui est partagé aujourd'hui : maintenance, supervision, mises à niveau et correctifs deviennent la charge de l'équipe du ministère
- **Toutes les données d'un pays peuvent être exportées intégralement à tout moment**, quel que soit l'hébergement

Le chemin vers l'appropriation par le pays

Pour les pays qui souhaitent s'héberger eux-mêmes, un effort du ministère de la Santé sera nécessaire. Une équipe devra faire tourner serveurs, sauvegardes et mises à niveau ; et des marchés devront être en place pour l'hébergement et pour les services d'IA, achetés auprès d'un fournisseur commercial (par ex. Anthropic, OpenAI).



L'essentiel

- **Des totaux mensuels uniquement** — jamais de dossiers patients
- **Une installation par pays** — aucun passage entre pays
- **Environ 12 000 USD par an** de fonctionnement — hébergement, IA au compteur, maintenance partagée ; ni licence ni frais par utilisateur
- **Hébergement par le pays d'ici 2030** — l'objectif de transition affiché

Annexe technique — pour les équipes informatiques et DHIS2

Architecture et isolation

- Chaque instance pays est un **déploiement Docker séparé** : son conteneur applicatif, sa base **PostgreSQL**, son cache **Valkey**, son volume de stockage, sur un réseau privé
- Au sein d'une instance, chaque projet a sa **propre base** (`project_{uuid}`) pour le contenu d'édition
- Les résultats calculés résident dans des **paquets de résultats versionnés** (fichiers parquet, interrogés via DuckDB) — les projets lisent le paquet qui leur est rattaché, jamais celui des autres

Authentification et contrôle d'accès

- L'identité est gérée par **Clerk** (fournisseur d'identité géré) ; les jetons de session sont **vérifiés par middleware à chaque requête** — le contournement d'authentification n'existe qu'en développement local, désactivé en production
- **RBAC à deux niveaux** : permissions d'instance et rôles par projet, résolus en base à chaque requête
- Accès aux serveurs : **SSH par clé cryptographique uniquement**, restreint à deux ingénieurs nommés — pas de connexion par mot de passe

Protection des données et exploitation

- **TLS terminé sur nginx**, certificats provisionnés et renouvelés via certbot ; les secrets sont injectés en variables d'environnement à l'exécution — jamais dans les images, jamais côté navigateur
- **Les modules R s'exécutent dans des conteneurs éphémères** (supprimés à la fin) qui ne montent que le répertoire de travail de leur exécution
- Sauvegardes : **pg_dump toutes les 30 minutes** (fenêtre glissante de 3 jours) plus **instantanés de volume quotidiens / hebdomadaires / mensuels** ; la restauration est contrôlée par permission (`can_restore_backups`) et par une clé côté serveur en plus d'une session valide

L'intégration IA, précisément

- Claude (Anthropic) est atteint via un **proxy côté serveur** ; la clé d'API ne quitte jamais le serveur
- Les appels d'outils s'exécutent **dans la session authentifiée de l'utilisateur** — l'IA n'a aucune permission propre
- Les outils de données renvoient **uniquement des sorties métriques agrégées** : il n'existe **aucune dimension identifiant d'établissement** dans l'interface de requête, et toute dimension de plus de 20 valeurs est résumée en nombre
- La **recherche web côté serveur (hébergée par Anthropic) est activée** dans le chat projet pour les questions générales
- Chaque requête est journalisée (utilisateur, projet, modèle, jetons) ; **des limites quotidiennes par utilisateur et hebdomadaires par instance** s'appliquent

Données et interopérabilité

- Données source : **numérateurs DHIS2 agrégés** (totaux établissement-mois) — importés côté serveur, avec remplacement par paire (indicateur, mois) et un registre d'importation par indicateur
- **Export intégral à tout moment** : les données et résultats d'un pays sont exportables quel que soit l'hébergement
- Le code est **open source** : github.com/FASTR-Analytics/platform